

FULLPAY LATAM (FICTICIA)

Operador de Importancia Vital (OIV) - Sector Fintech

Alineación estratégica: Ley 21.663 + ISO/IEC 27001:2022

Junio, 2026

AUTOR:

Joaquín Picazo

1. Resumen ejecutivo

FullPay Latam enfrenta un desafío operativo. El negocio necesita la certificación ISO 27001 para expandirse, pero al mismo tiempo está obligado a cumplir la nueva Ley 21.663 para no arriesgar multas millonarias por parte de la ANCI. Gestionar ambos por separado es un desgaste enorme para los equipos de tecnología y un gasto innecesario de presupuesto.

Tratar de armar dos procesos distintos genera duplicidad de trabajo y papeleo inútil. Este documento propone una ruta mucho más eficiente. Es un modelo unificado para que la empresa implemente un solo control técnico que le sirva tanto al auditor internacional como al fiscalizador del Estado. Es una forma directa de proteger la operación y asegurar que el directorio no corra riesgos legales por falta de alineación.

2. Metodología de evaluación

Para esto se realizó un mapeo cruzado. Se analizó el texto legal de la ley chilena (21.663) y se comparó directamente con los controles del Anexo A de la norma ISO 27001.

Todo el análisis se concentra en tres pilares fundamentales para la empresa. El primero es la **gobernanza** y cómo la alta gerencia responde ante la ley. El segundo es la **gestión de incidentes**, enfocado en el desafío técnico de reportar ciberataques al gobierno en un plazo máximo de tres horas. El tercero es la **continuidad operacional**, para asegurar que los planes de contingencia cumplan los plazos obligatorios de certificación que exige el Estado para mantener el negocio funcionando.

3. Cruce de controles: ISO 27001 y Ley 21.663

Las siguientes tablas muestran el cruce directo entre la norma ISO 27001 y la Ley 21.663. El análisis se enfocó exclusivamente en tres áreas: gobernanza, gestión de incidentes y continuidad operacional.

3.1 Gobernanza

Ley 21.663	ISO 27.001	Brecha legal	Remediación
Art. 8 (a): Implementar SGSI continuo para evaluar probabilidad e impacto sobre la continuidad del negocio.	Cláusula 6.1.2: Exige evaluar riesgos según consecuencias y probabilidad.	La ley exige jurídicamente mantener el servicio vital, yendo más allá de un simple proceso interno.	Alinear la evaluación de riesgos con las definiciones legales de impacto crítico para el servicio.
Art. 8 (i): Designar un "delegado de ciberseguridad" que actúe como contraparte oficial de la ANCI.	Cláusula 5.3 y A.5.5: Asignar responsabilidades de seguridad y mantener contacto con autoridades.	La ISO pide mantener contacto. La ley exige una figura legal unipersonal vinculante y con representación ante el Estado.	Formalizar mediante resolución o acta directiva el nombramiento del Delegado de Ciberseguridad con poder ante la ANCI.
Art. 8 (i): El delegado debe informar de su gestión explícitamente a los directores, gerentes o administradores.	Cláusula 9.3: La alta dirección debe revisar el SGSI a intervalos planificados.	La norma exige una revisión general. La ley personaliza y obliga al delegado a rendir cuentas formales al directorio.	Integrar al Delegado de Ciberseguridad como expositor obligatorio y documentado en los comités de Revisión por la Dirección.
Art. 8 (h): Ejecutar programas de formación obligatorios sobre "ciberhigiene".	Cláusulas 7.2, 7.3 y A.6.3: Pide educar y generar conciencia en seguridad.	La ISO es genérica, pero la ley impone taxativamente ejecutar campañas específicas de "ciberhigiene".	Integrar módulos obligatorios llamados explícitamente "ciberhigiene" en el plan anual corporativo.
Art. 11 (ñ, o): La ANCI puede ordenar auditorías externas y citar a declarar a directores por infracciones.	Cláusula 9.2 y A.5.35: Exige auditorías internas y revisiones independientes planificadas.	La norma solo pide revisiones independientes. La ley expone al directorio a interrogatorios y auditorías estatales.	Crear un protocolo de contingencia legal para proteger al directorio ante fiscalizaciones de la ANCI.

Art. 7 y 47: Obligación de aplicar protocolos dictados por la ANCI y corregir infracciones detectadas.	Cláusula 10.2 y A.5.31: Pide cumplir leyes y gestionar no conformidades.	ISO asume correcciones internas. La ley obliga a adoptar medidas dictadas por una entidad fiscalizadora gubernamental.	Crear un flujo prioritario en el SGSI para incluir y auditar los protocolos emitidos por la ANCI.
Art. 8 (b): Exige mantener un registro de las acciones que compongan el SGSI.	Cláusula 7.5 y A.5.33: Mantener y proteger la documentación del SGSI.	Para ISO es control de calidad interno. Para la ley, es un registro auditable directamente por el Estado.	Armar un repositorio centralizado e inmutable de la documentación, listo para presentar ante auditorías de la ANCI.

3.2 Incidentes

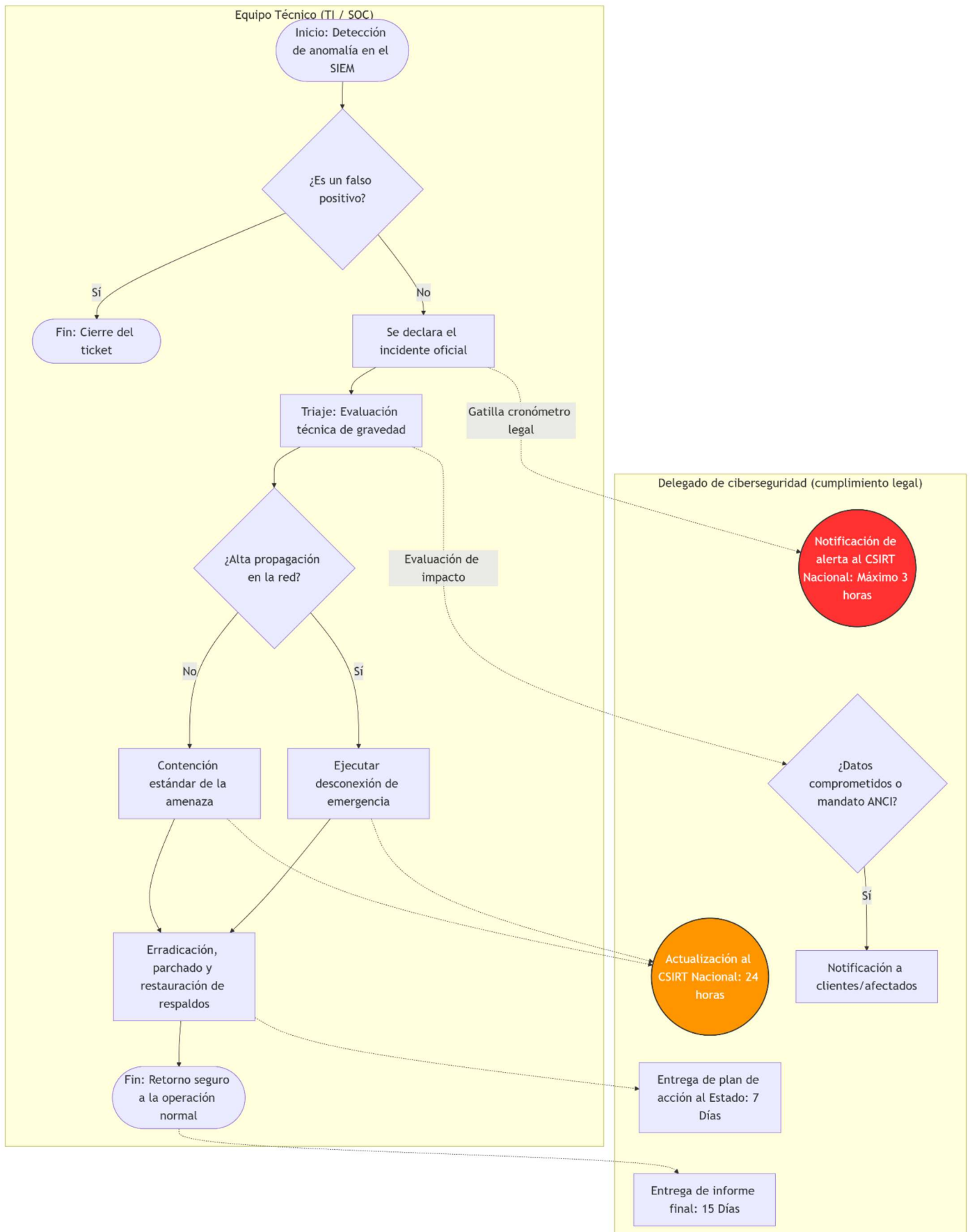
Ley 21.663	ISO 27.001	Brecha legal	Remediación
Art. 9 (a-d): Reportar al CSIRT: alerta en 3 horas, actualización en 24h y plan en 7 días.	Controles A.5.24 y A.5.26: Planificar y responder a incidentes documentados.	La norma no define tiempos. La ley fija plazos estrictos en horas para avisar al Estado.	Ajustar manuales con tiempos legales y crear alertas automáticas para reportar en 3 y 24 horas.
Art. 9 (b) y 27: Evaluar gravedad según cantidad de personas, duración y alcance geográfico.	Control A.5.25: Evaluar eventos para definirlos como incidentes.	ISO no da métricas. La ley fija criterios exactos para definir un ataque significativo.	Adaptar la matriz de triaje para medir criticidad por impacto en personas, tiempo y geografía.
Art. 9 (c): Entregar informe final en 15 días con las medidas de mitigación aplicadas.	Control A.5.27: Usar el aprendizaje de incidentes para mejorar controles.	Para ISO es mejora continua interna. La ley exige reportar y justificar al CSIRT Nacional.	Ajustar reportes para enviar las mitigaciones al CSIRT Nacional en 15 días.
Art. 8 (g): Informar a usuarios si el ataque compromete sus datos o redes.	Control A.5.26: Responder incidentes según documentación.	La norma no obliga a notificar a clientes o víctimas externas.	Crear plantillas de comunicación validadas legalmente para avisar a clientes afectados.

Art. 3 (1) y 8 (e): Obliga a contener el daño, permitiendo restringir accesos a sistemas.	Control A.5.26: Seguir los procedimientos de respuesta.	La ley autoriza expresamente la desconexión de emergencia; la norma solo sugiere control.	Dar poder al equipo técnico para aplicar desconexiones de emergencia
Art. 11 (j): La ANCI exige logs, pero con datos personales anonimizados.	Controles A.5.28, A.8.15 y A.8.11: Guardar evidencia, logs y enmascarar datos.	La ISO los trata por separado. La ley obliga a cruzarlos para entregar logs sin revelar identidades.	Configurar enmascaramiento automático en el SIEM para enviar logs legales rápido.
Art. 8 (d): Hacer simulacros y compartir hallazgos de amenazas con el CSIRT Nacional.	Controles A.5.24, A.8.16, A.5.7: Monitorear redes y generar inteligencia de amenazas.	La norma no obliga a compartir las amenazas detectadas con el Estado.	Enviar automáticamente los Indicadores de Compromiso (IoCs) de simulacros al CSIRT Nacional.

3.3 Continuidad

Ley 21.663	ISO 27.001	Brecha legal	Remediación
Art. 8 (c): Auditar y certificar planes de continuidad al menos cada dos años.	Control A.5.30: Probar y mantener la continuidad TIC del negocio.	La norma no da plazos. La ley exige una certificación externa obligatoria cada dos años.	Probar anualmente y contratar a un auditor validado por la ANCI cada dos años.
Art. 2 (13) y 8 (e): Obliga a la resiliencia operativa, manteniendo el servicio en modo degradado.	Control A.5.29: Mantener la seguridad durante una caída.	ISO protege la seguridad. La ley te obliga a mantener el servicio operando cueste lo que cueste.	Rediseñar la red para que el negocio siga operando en "modo degradado" con alta redundancia.

4. Foco crítico: Flujo de gestión de incidentes



5. Hoja de ruta (plan de acción)

A continuación se presenta un plan de acción a 90 días. El objetivo es cubrir los puntos legales más peligrosos/urgentes primero.

Fase 1 (primeros 30 días):

- Firmar el documento legal que nombra oficialmente al Delegado de Ciberseguridad. Es urgente tener esa firma para tener una contraparte válida ante la ANCI.
- Configurar las reglas del sistema de monitoreo para que dispare la alerta de impacto. El equipo debe empezar a entrenar hoy mismo bajo el nuevo límite de 3 horas para notificar incidentes al gobierno ante un incidente real.

Fase 2 (a los 60 días):

- Levantar presupuesto y agendar la auditoría de los planes de contingencia (BCP y DRP).
- Asegurar por contrato que la empresa externa que audite esté acreditada en el registro oficial de la ANCI. Con esto cumplir dos cosas en una sola: cumplir el ciclo obligatorio de dos años de la ley y generar evidencia para la ISO 27001.

Fase 3 (a los 90 días):

- Coordinar con recursos humanos el lanzamiento de los módulos de capacitación obligatorios para toda la empresa.
- Implementar la herramienta técnica para enmascarar los datos personales en los logs antes de enviarlos al Estado, cumpliendo con la exigencia de anonimización.

